

Certificate / Workload-Identity Signing

Architecture for 1,000–5,000 TPS under a FIPS 140-3 Level 1 Floor

ADR	
Status	Proposed
Date	2026-06-04
Deciders	Cyber Architecture / PKI / Platform Engineering
Environment	Regulated enterprise (PCI-DSS L1); ~1.2M agents; SPIFFE/SPIRE, Athenz
Recommendation	Option D (tiered) — realised at the issuance tier as Option E (Nitro Enclaves)

Status markers (no icons). This document uses text markers instead of symbols.

Confirmed — published/deployed and verified.

Verify — reconfirm against current AWS pricing / quota / the CMVP Active Validation List before ratification.

Caution — a material caveat affecting the audit or the decision; read the adjacent note.

1 Context and problem statement

We need a signing tier for certificate / workload-identity issuance that can sustain 1,000, 2,000, and 5,000 signing operations per second (sizing tiers, not one fixed target). The minimum acceptable cryptographic assurance is FIPS 140-3 Level 1; higher is acceptable where justified by cost and operational fit. For each option the decision states the FIPS 140-3 level actually satisfied, NIST algorithm-level compliance, scaling to each TPS tier, and cost shape.

Two non-obvious facts drive the analysis:

1 • Level 1 is a software-correctness floor only. It carries no physical-security and no operator-authentication requirement. It validates that approved algorithms are implemented correctly — it says nothing about protecting a long-lived key from host compromise. "L1 at least" is met by every option; root key custody is a separate control we call out explicitly.

2 • The FIPS level depends on where the signing executes, not on which products are in the diagram. A design that "uses KMS" is only L3 for the operations KMS actually performs. If high-volume signing runs in a software module, that path is L1 regardless of what anchors the root.

2 Decision drivers

- **Assurance:** FIPS 140-3 Level 1 minimum; hardware (L3) custody for the root strongly preferred.
- **Throughput:** scale cleanly across 1k / 2k / 5k TPS with N+1 HA.
- **Cost shape:** flat vs. per-operation; behaviour under sustained vs. bursty duty cycle.
- **Operational burden:** managed service vs. self-run cluster vs. self-run fleet.
- **Auditability:** a validated certificate issued (not merely "in process") at ratification time.
- **Agility:** rotate algorithms (FIPS 186-5 / SP 800-131A) and adopt PQC later.

3 Key facts (verified 2026-06-04)

Fact	Value	Status
CloudHSM instance type	Only hsm2m.medium (L3); hsm1.medium EoS 2026-03-31	Confirmed
CloudHSM throughput / HSM	RSA-2048 ~1,000/s; EC P-256 ~1,500/s; EC P-384 ~600–900/s	P-384: Verify
CloudHSM cost	~\$1.45–1.60/HSM/hr (~\$1,059–1,168/mo)	Verify (region)
KMS HSM validation	FIPS 140-3 Level 3	Confirmed
KMS crypto-ops rate	~300–500/s default, shared per account+region	Confirmed
KMS Sign pricing	RSA-2048 ~\$0.03/10k; ECC ~\$0.15/10k	Verify
AL2023 FIPS (Kernel Crypto API)	Validated, certificate #4808	Confirmed / deployed
AL2023 FIPS (OpenSSL/NSS/GnuTLS/Libgcrypt)	Modules-In-Process (MIP) — awaiting CMVP cert	Caution — aspirational
FIPS 140-2 modules	Historical after 2026-09-21 — do not build on them	Confirmed

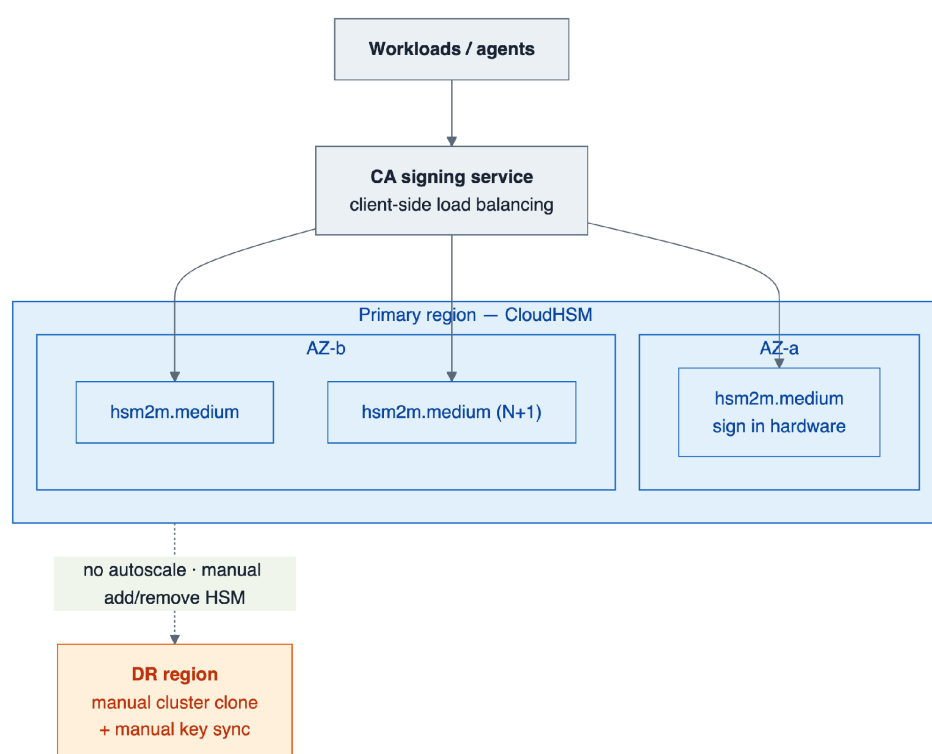
Caution — material audit caveat. Most TLS/X.509 signing paths use OpenSSL, whose AL2023 FIPS 140-3 certificate is not yet issued (MIP). Through the Kernel Crypto API module (#4808) the path is validated today; through OpenSSL it is "in process." A strict PCI assessor may accept MIP or require an issued certificate — confirm before relying on the OpenSSL path.

For context, software throughput per core (order of magnitude): ECDSA P-256 ~20k–40k/s, P-384 ~3k–8k/s, RSA-2048 sign ~1k–2k/s. Throughput is never the constraint for software options — assurance and key custody are.

4 Considered options

Option A — Scale a CloudHSM cluster (signing inside the HSM)

Keys are generated and never leave the hsm2m.medium HSM; every signature executes in hardware.



Option A — CloudHSM cluster across AZs (L3); no autoscaling; cross-region DR is a manual clone.

FIPS satisfied: 140-3 Level 3 (tamper-evident hardware, operator auth, physical security). Exceeds the floor.

Scaling (incl. N+1 HA):

TPS	RSA-2048 HSMs	EC P-256 HSMs
1,000	2	2
2,000	3	2–3
5,000	6	4–5

Cost shape: Flat, duty-cycle independent. ~\$2.3k/mo (2 HSM) to ~\$7k/mo (6 HSM). Verify.

Pros

- Highest assurance; single-tenant; key never in general-purpose memory.

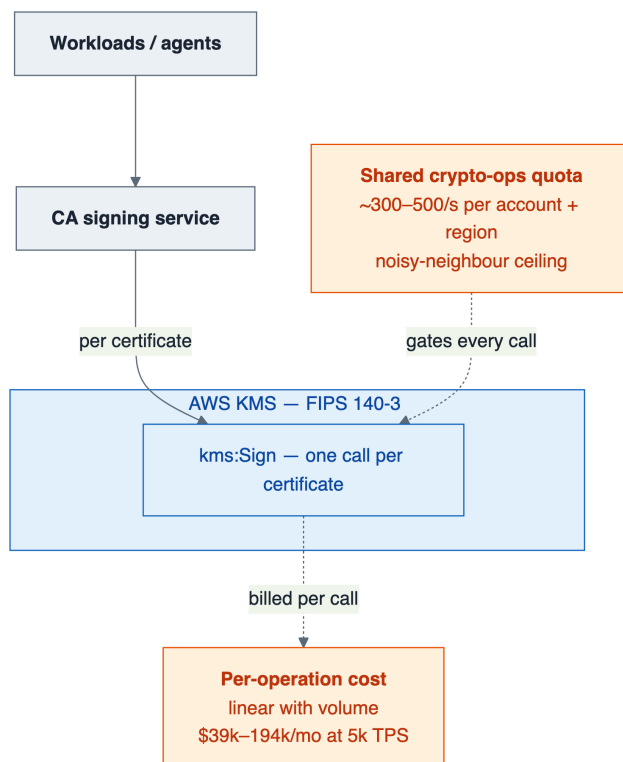
- Bounded, predictable cost at high sustained TPS.

Cons

- You operate the cluster (quorum, backups, AZ spread).
- Fixed per-HSM throughput; coarse ~1k-TPS (RSA) scaling increments; 3,333 keys/cluster cap.
- No native autoscaling; multi-region needs a cloned cluster with manual key sync.

Option B — KMS direct asymmetric signing

The application calls KMS Sign for each certificate; the key resides in KMS HSMs.



Option B — per-cert kms:Sign (L3 via FIPS endpoint), gated by a shared crypto-ops quota and per-op cost.

FIPS satisfied: 140-3 Level 3 — only if the SDK targets the FIPS endpoints (kms-fips.<region>.amazonaws.com).

Scaling: Gated by the shared crypto-ops quota (~300–500/s, per account and region). 5,000 TPS needs a ~10× Service Quotas increase (not guaranteed; contends with all KMS consumers).

Cost @ sustained TPS (Verify):

TPS	RSA-2048 (\$0.03/10k)	ECC (\$0.15/10k)
1,000	~\$7.8k/mo	~\$38.9k/mo
5,000	~\$38.9k/mo	~\$194k/mo

Pros

- Fully managed; zero crypto infra; instant HA/DR.
- Cheapest for low or bursty duty cycles — pay only for calls made.

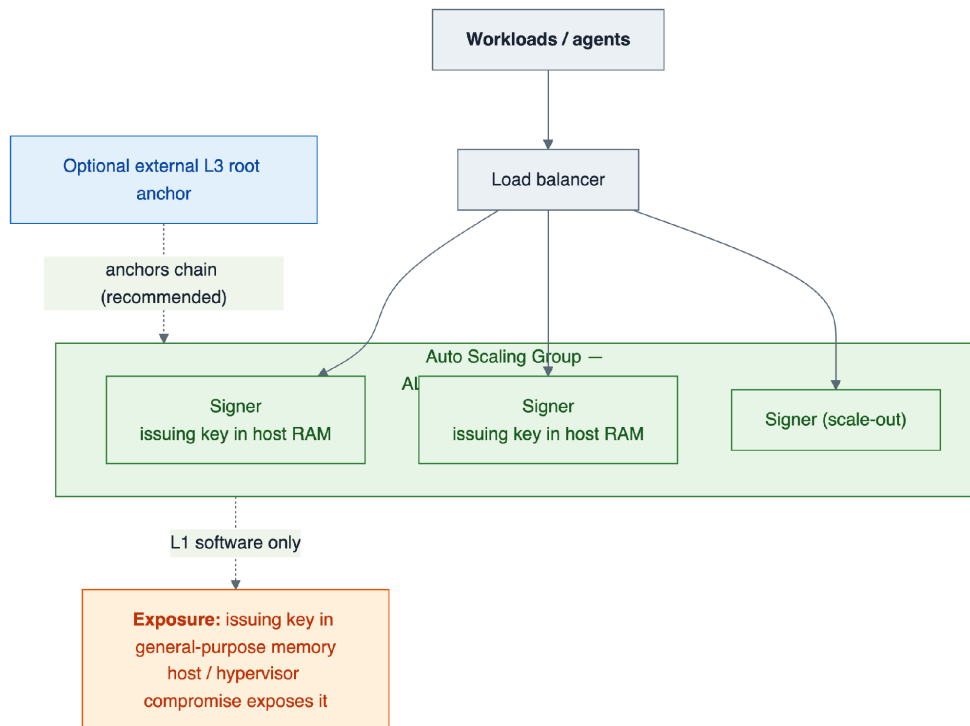
Cons

- Shared quota is a hard ceiling and a noisy-neighbour risk within the account.
- Dramatically the most expensive option at sustained high TPS.
- Per-call latency added to issuance.

Variant B' — CloudHSM-backed KMS custom key store: KMS ergonomics + single-tenant residency; bounded by both the KMS quota and the backing cluster. A key-residency play, not a throughput win.

Option C — Software signing on AL2023 FIPS mode, auto-scaled

Intermediate/issuing key held in memory on AL2023 instances in FIPS mode; signing in the AL2023 module; scale via an ASG.



Option C — auto-scaled AL2023 FIPS signer fleet (L1, key in host memory), optionally anchored to an external L3 root.

FIPS satisfied: 140-3 Level 1 — validated today only via the Kernel Crypto API module (#4808); MIP if via OpenSSL/NSS/GnuTLS/Libgcrypt.

Scaling: Trivial — a few cores cover 5,000 TPS for ECDSA. Cost near-flat (low hundreds \$/mo).

Pros

- Cheapest; effortless throughput; cloud-native autoscaling; algorithm-agile.

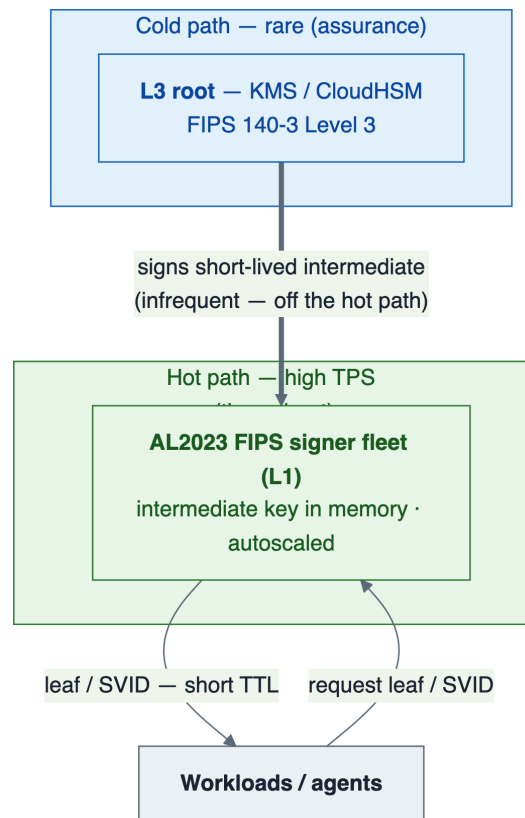
Cons

- Issuing key in general-purpose memory, protected only at L1 — host/hypervisor compromise exposes it.
- Unacceptable as a standalone root; only for short-TTL issuance with the root anchored elsewhere (Option D).
- OpenSSL MIP caveat applies.

Option D — Tiered: L3 root → L1 auto-scaled intermediate → leaf SVIDs

[RECOMMENDED]

The root/issuing key sits in KMS or CloudHSM (L3) and signs a short-lived intermediate infrequently. High-volume leaf/SVID issuance runs on the AL2023 FIPS (L1) auto-scaled fleet — the SPIFFE/SPIRE-native pattern.



Option D — rare L3 root signs the intermediate (cold path); L1 fleet issues SVIDs at high TPS (hot path).

FIPS satisfied: L3 for the root anchor; L1 for high-volume issuance. Meets the floor and gives a hardware-rooted chain.

Scaling: Software tier scales to 5,000 TPS+ trivially; KMS/CloudHSM only for rare intermediate renewals — never on the hot path. Best \$/TPS at every tier.

Pros

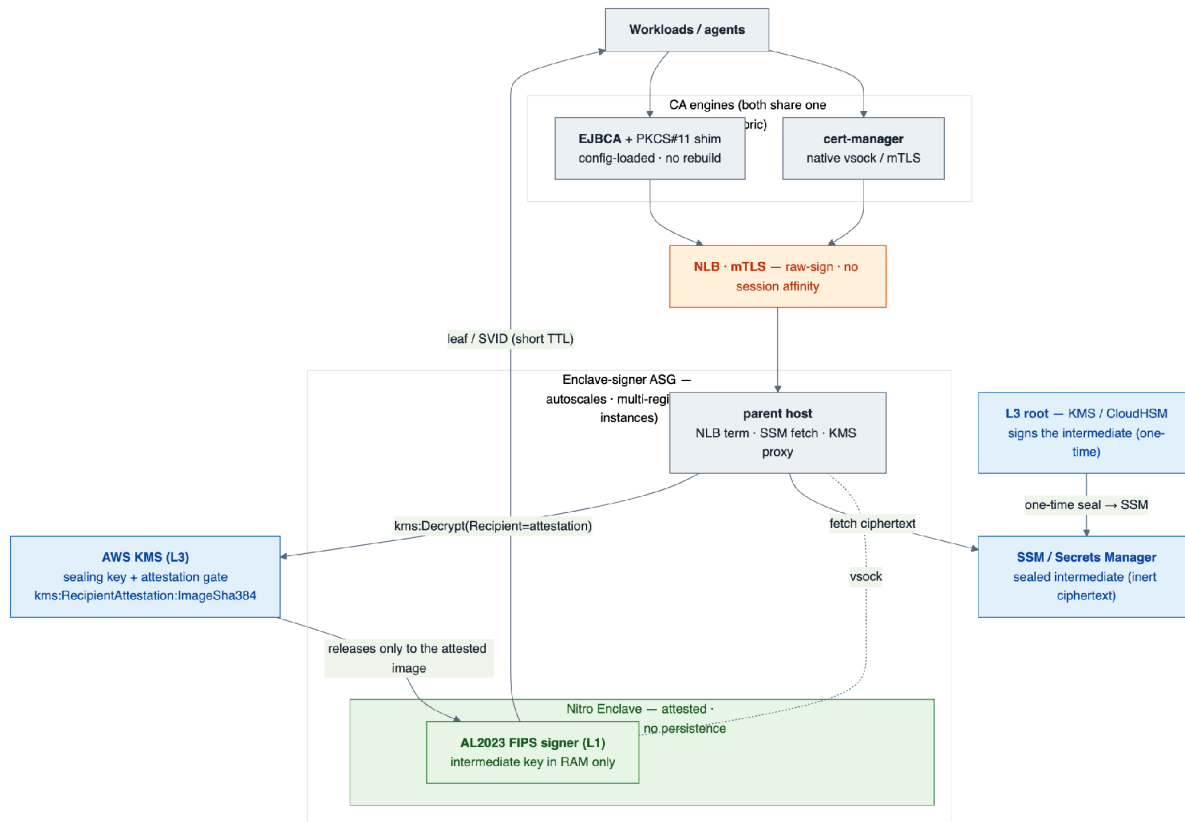
- Decouples assurance (root) from throughput (leaf); cheapest at scale.
- Quota/throughput pressure eliminated; aligns with existing SPIRE/Athenz direction.

Cons

- Issuance-tier assurance is L1 — mitigated by short TTLs (a compromised leaf key is valid only minutes, never persisted).
- More moving parts than a single managed service; OpenSSL MIP caveat applies to the leaf module.

Option E — Nitro Enclaves + AL2023 FIPS (hardened L1) [RECOMMENDED for the issuance tier]

Run the intermediate signer of Option D inside AWS Nitro Enclaves: isolated memory, no persistence, no interactive access, with KMS key release gated on enclave attestation. This is the fully-designed realisation of Option D's issuance tier — it closes the host-memory exposure gap without L3 cost.



Option E — L3 root seals the intermediate to SSM; KMS releases it only to an attested enclave image; the L1 AL2023 FIPS signer runs in-enclave and serves both cert-manager (native) and EJBICA (PKCS#11) from one fabric.

How it works

1. The L3 root signs a short-lived intermediate once; its private key is sealed (kms:Encrypt) to inert ciphertext in SSM/Secrets Manager (best: generate + seal inside a bootstrap enclave so plaintext never leaves an enclave).
2. On boot the parent fetches the ciphertext; the enclave produces an NSM attestation and calls kms:Decrypt with the attestation as Recipient.
3. KMS releases the key only to a matching image — condition key kms:RecipientAttestation:ImageSha384. The key then lives only in enclave RAM.
4. High-volume leaf/SVID issuance runs inside the enclave. KMS is touched once per instance boot, never per certificate.

Fleet, scaling, multi-region. An ASG behind an NLB scales on sign-rate to any TPS. Every instance releases the same sealed intermediate → one issuer identity, no session affinity. Multi-region is native: replicate the inert ciphertext to each region's SSM — no cluster cloning or manual key sync.

Consumers. cert-manager reaches the signer natively (vsock/mTLS); EJBCA reaches it via a config-loaded PKCS#11 module (no EJBCA rebuild) that forwards a raw signature over mTLS to the same fleet.

FIPS satisfied: 140-3 Level 1 crypto plus hardware memory isolation and attestation — stronger key-in-memory protection than plain L1, without L3 cost. The enclave image must carry its own FIPS module (host FIPS mode does not extend in). Also enables hybrid/PQC (ML-DSA, composite) that HSM firmware cannot.

Pros

- Closes the host-memory exposure gap of C/D — only the attested image can use the key.
- Elastic autoscaling and native multi-region at software cost; one shared ICA fleet-wide.
- Serves both cert-manager (native) and EJBCA (config-loaded PKCS#11) from one fabric; PQC-capable.

Cons

- Highest operational complexity of the L1 options; an enclave build/attestation pipeline is required.
- The in-enclave FIPS module must be validated / MIP-tracked separately.
- The raw-sign endpoint is a signing oracle — mTLS-lock it; the instance IAM role must not hold kms:Decrypt (attestation-gated release only).

Correction from live validation. The KMS condition key is kms:RecipientAttestation:ImageSha384, not ...:PCRO — an unrecognised condition key silently denies. A --debug-mode enclave zeroes its measurement and will not match a production policy.

5 Comparison summary

	A: CloudHSM	B: KMS direct	C: AL2023 SW	D: Tiered (rec.)	E: Enclave + FIPS
FIPS 140-3 level	L3	L3 (FIPS endpoint)	L1 (Caution: MIP)	L3 root / L1 leaf	L1 + HW isolation
Meets L1 floor	Yes (exceeds)	Yes (exceeds)	Yes	Yes	Yes
Hardware root custody	Yes	Yes	No (needs anchor)	Yes	Yes (via KMS)
5,000 TPS feasible	Yes (6 HSM)	Caution: 10× quota	Yes (easily)	Yes (easily)	Yes (easily)
Autoscaling	No	Managed	Yes	Yes	Yes
Multi-region	Manual clone	Native	Native	Native	Native (sealed blob)
Cost @ sustained 5k TPS	~\$7k/mo flat	\$39k–194k/mo	~hundreds \$/mo	~hundreds + tiny KMS	~hundreds \$/mo
Cost @ low / bursty	poor (still flat)	best	best	best	best
PQC / hybrid capable	No (firmware)	No	Yes	Yes	Yes
Ops burden	high	lowest	medium	medium-high	highest
Audit-ready today	Yes	Yes	Caution: MIP	Yes root / Caution leaf	Caution: MIP

6 Decision outcome

Recommended: Option D (tiered, L3 root → L1 auto-scaled issuance), realised at the issuance tier as Option E (Nitro Enclaves + AL2023 FIPS) wherever host-memory exposure of the intermediate key is in scope.

D is the only option that satisfies the FIPS 140-3 L1 floor, provides a hardware-rooted (L3) trust anchor, scales to 5,000 TPS without hitting the KMS shared quota or the CloudHSM per-HSM ceiling, and has the best cost at every TPS tier. Option E adds hardware memory isolation and attested key release at software cost, plus native multi-region and PQC/hybrid capability. Both align with the existing SPIFFE/SPIRE / Athenz direction.

Fallbacks by constraint

- If a regulator/assessor requires the issuing key (not just the root) in hardware → **Option A** at the issuance tier, sized per the table (higher cost, per-HSM scaling).
- If the duty cycle is genuinely low/bursty and simplicity dominates → **Option B** is cheapest and zero-ops, provided the quota covers peak.

7 Consequences

- Anchor the root in KMS or CloudHSM and keep intermediate TTLs short (bounds the blast radius of the L1 issuance tier).
- Resolve the OpenSSL-MIP question with the PCI assessor before ratification, or route signing through the Kernel Crypto API module (#4808).
- Do not build any path on FIPS 140-2 modules (Historical after 2026-09-21).
- Root/intermediate KMS calls must use FIPS endpoints and instance-role credentials; high-TPS leaf signing must not call KMS per-certificate.
- Option E: the instance IAM role must not hold kms:Decrypt (attestation-gated only); mTLS-lock the raw-sign endpoint; verify the released key matches the pinned intermediate cert and chains to the expected root.
- Add CloudWatch alarms on KMS crypto-ops quota utilisation even in Option D/E (intermediate-renewal spikes).
- Revisit when ML-DSA on CloudHSM exits preview and AL2023's OpenSSL FIPS 140-3 certificate is issued.